

Trame de rapport — Audit d'eRezo & conception de la V2

Modèle à remplir par votre société de conseil. Remplacez chaque bloc en italique par votre analyse. Le rapport final est rendu en PDF **en fin de module**, à partir du travail réalisé **en séance**. Soyez concis et factuel : un bon rapport tient en 6 à 10 pages.

Page de garde

- **Rapport** : Audit d'eRezo (infrastructure & sécurité) & recommandations pour la V2
- **Réalisé par (votre société de conseil)** : *nom de votre société*
- **Consultant(s)** : *vous, seul ou avec votre associé*
- **Client** : KodeSaaS — Maxime Nicole (propriétaire d'eRezo)
- **Date de l'audit** : *date*
- **Périmètre** : audit de l'existant sur la production <https://erezo.fr> (lecture seule) — **infrastructure & sécurité, hors code source** · recommandations d'**architecture pour la V2**
- **Autorisation de test signée** : *oui / n° annexe*

1. Résumé exécutif

En 5-8 lignes, pour votre client :

- *État général côté infrastructure et sécurité (sain / à surveiller / à risque)*
- *Les 2-3 points les plus importants*
- *Votre recommandation d'architecture principale pour la V2*

Score de risque global (sécurité) : *X / 10*

Sévérité	Nombre de failles
Critique (P0)	<i>n</i>
Haute (P1)	<i>n</i>
Moyenne / Basse (P2)	<i>n</i>

2. Audit de l'infrastructure

Tout ce que vous avez pu observer de l'extérieur. Pour chaque point : ce que vous constatez, et pourquoi c'est un problème (ou pas).

Hébergement : *Où et comment l'application semble hébergée (serveur, hébergeur, CDN...), et comment vous l'avez identifié (DNS, en-têtes...). Écrivez « non confirmé » si vous n'êtes pas sûr.*

HTTPS / certificat : *Le site est-il en HTTPS ? Le certificat est-il valide et correctement configuré ?*

En-têtes HTTP & configuration : *En-têtes de sécurité présents ou absents, messages d'erreur trop bavards, pages ou fichiers exposés qui ne devraient pas l'être, robots.txt, etc.*

Traces de « fait vite » : *Environnement de dev visible en prod, informations techniques qui fuient, incohérences...*

Verdict infrastructure : *points forts / points faibles / recommandations.*

3. Audit de sécurité (pentest — OWASP)

Rappel : **lecture seule, non destructif**. Aucune donnée personnelle réelle ne doit apparaître dans ce rapport (anonymisez).

Méthodologie : *outils / agents IA utilisés, phases (reconnaissance → tests → vérification).*

Findings

Pour **chaque faille** trouvée, remplissez :

[FIND-00X] Titre

- **Sévérité** : Critique / Haute / Moyenne / Basse · **Priorité** : P0 / P1 / P2
- **Zone concernée** : page, endpoint, fonctionnalité...
- **Description** : en quoi consiste la faille.
- **Preuve** : comportement observé, capture anonymisée.
- **Impact** : ce que ça permet à un attaquant.
- **Correction recommandée** : ...

(Dupliquez ce bloc pour chaque finding.)

Points positifs (ce qui est bien sécurisé)

Listez ce qui résiste. Un bon auditeur note aussi ce qui va bien.

Plan de remédiation priorisé

Priorité	Faille	Effort estimé	Impact
P0	...	faible/moyen/élevé	...
P1	...	...	...
P2	...	...	...

4. Recommandations pour la V2

Comment reconstruire eRezo : une V2 bien architecturée, testée, bien hébergée et sécurisée. Pour chaque thème : la bonne pratique, **pourquoi** elle compte, et ce que vous recommandez concrètement au client. Sur les volets A, B et C, **c'est à vous de mobiliser et de nommer** les bons concepts et outils — c'est précisément ce qui est évalué.

A. Architecture & conception

Comment structurer la V2. Nommez vous-mêmes les approches que vous recommandez.

- **Découpage du métier** : comment vous structureriez les domaines de l'application et leurs frontières.
- **Séparation cœur métier / infrastructure** : comment isoler le métier des détails techniques.
- **Langage du métier** : comment le code reflète le vocabulaire métier.
- **Couplage & évolutivité** : où placer les frontières pour limiter le couplage.

B. Qualité & tests

- **Stratégie de tests** : quelle démarche, et à quel moment écrire les tests.
- **Types & proportions** : quels niveaux de tests, et ce que vous testez en priorité (cœur métier).
- **Intégration continue & conventions** : comment tenir la qualité dans la durée.

C. Un projet fait pour l'IA & reprenable

- **Outils IA du dépôt** : rôle de `CLAUDE.md` / `AGENTS.md` (contexte et règles pour les agents), des **Skills** (compétences réutilisables), du **MCP** (connexion des agents aux outils / données).
- **Documentation d'onboarding** : README, doc d'architecture — le « test du freelance » (< 30 min).
- **Reprenabilité & durabilité** : en quoi ces choix rendent la V2 reprenable.

D. Infrastructure, sécurité & données

- **Infrastructure propre** : hébergement, HTTPS partout, séparation dev / production, sauvegardes.
- **Application sécurisée** : règles pour éviter précisément les failles trouvées (accès, en-têtes, config, données exposées).
- **Mise en ligne maîtrisée** : déploiement propre, du poste dev à la production.

- **Respect des données des utilisateurs** : règles de base sur les données personnelles.
-

5. Synthèse des recommandations

Top 5 des actions à conseiller au client, dans l'ordre où vous lui conseillez de les traiter (mêlez sécurité, infra et architecture).

1. ...
 2. ...
 3. ...
 4. ...
 5. ...
-

Annexe A — Méthode & outils IA

Comment vous avez conduit l'audit et rédigé les recommandations avec l'IA : prompts, agents, MCP, outils. La méthode fait partie de la compétence évaluée.

Annexe B — Audit croisé

Commentaires reçus d'une autre société (autre groupe) sur votre rapport (séance 5) et comment vous les intégrez.